

Introduction au labo (Kali + Metasploitable2)

Report 02

Name :Mostefaoui Manel

Groupe :01

Module: Computer science and network security

1.introduction :

Objective :

The primary objectives of this practical work were to:

- Configure and verify network connectivity between penetration testing tools and target systems
- Perform network reconnaissance using various discovery techniques
- Conduct port scanning and service enumeration to identify potential attack surfaces
- Interact with vulnerable services in a non-destructive manner
- Capture and analyze network traffic to understand protocol security implications
- Document findings and understand the methodology of ethical hacking

Environment

- Virtualization: VirtualBox / VMware (circle one)
- Kali Linux (attacker platform)
- Metasploitable2 (vulnerable target)
- Network: Host-Only

2.Exercise 1

Deliverable:

```

root@kali:~# gpg --full-generate-key
gpg (GnuPG) 2.1.18; Copyright (C) 2017 Free Software Foundation, Inc.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.

Please select what kind of key you want:
  (1) RSA and RSA (default)
  (2) DSA and Elgamal
  (3) DSA (sign only)
  (4) RSA (sign only)
Your selection? 1
RSA keys may be between 1024 and 4096 bits long.
What keysize do you want? (2048) 1024
Requested keysize is 1024 bits
Please specify how long the key should be valid.
  0 = key does not expire
  <n> = key expires in n days
  <n>w = key expires in n weeks
  <n>m = key expires in n months
  <n>y = key expires in n years
Key is valid for? (0) 0
Key does not expire at all
Is this correct? (y/N) y

GnuPG needs to construct a user ID to identify your key.

Real name: studentA
Email address: studentA@gmail.com
Comment:
You selected this USER-ID:
  "studentA <studentA@gmail.com>"

Change (N)ame, (C)omment, (E)mail or (O)kay/(Q)uit? 0
Change (N)ame, (C)omment, (E)mail or (O)kay/(Q)uit? o
We need to generate a lot of random bytes. It is a good idea to perform

```

```

File Edit View Search Terminal Help
Requested keysize is 1024 bits
Please specify how long the key should be valid.
  0 = key does not expire
  <n> = key expires in n days
  <n>w = key expires in n weeks
  <n>m = key expires in n months
  <n>y = key expires in n years
Key is valid for? (0) 0
Key does not expire at all
Is this correct? (y/N) y

GnuPG needs to construct a user ID to identify your key.

Real name: studentA
Email address: studentA@gmail.com
Comment:
You selected this USER-ID:
  "studentA <studentA@gmail.com>"

Change (N)ame, (C)omment, (E)mail or (O)kay/(Q)uit? 0
Change (N)ame, (C)omment, (E)mail or (O)kay/(Q)uit? o
We need to generate a lot of random bytes. It is a good idea to perform
some other action (type on the keyboard, move the mouse, utilize the
disks) during the prime generation; this gives the random number
generator a better chance to gain enough entropy.
We need to generate a lot of random bytes. It is a good idea to perform
some other action (type on the keyboard, move the mouse, utilize the
disks) during the prime generation; this gives the random number
generator a better chance to gain enough entropy.
gpg: /root/.gnupg/trustdb.gpg: trustdb created
gpg: key 4ED0EDA9C27334BE marked as ultimately trusted
gpg: directory '/root/.gnupg/openpgp-revocs.d' created
gpg: revocation certificate stored as '/root/.gnupg/openpgp-revocs.d/D40C3E111C5F81EFD7A128C34ED0EDA9C27334BE.rev'
public and secret key created and signed.

pub   rsa1024 2025-10-15 [SC]
       D40C3E111C5F81EFD7A128C34ED0EDA9C27334BE
       D40C3E111C5F81EFD7A128C34ED0EDA9C27334BE
uid           studentA <studentA@gmail.com>
sub   rsa1024 2025-10-15 [E]

```

```
root@kali:~# gpg --list-keys
gpg: checking the trustdb
gpg: marginals needed: 3 completes needed: 1 trust model: pgp
gpg: depth: 0 valid: 1 signed: 0 trust: 0-, 0q, 0n, 0m, 0f, 1u
/root/.gnupg/pubring.kbx
-----
pub   rsa1024 2025-10-15 [SC]
      D40C3E111C5F81EFD7A128C34ED0EDA9C27334BE
uid           [ultimate] studentA <studentA@gmail.com>
sub   rsa1024 2025-10-15 [E]
```

```
root@kali:~# gpg --armor --export "studentA" > A pub.asc
```

```
root@kali:~# ls -l A pub.asc
```

```
-rw-r--r-- 1 root root 1042 Oct 15 05:18 A pub.asc
```

```
root@kali:~# cat A pub.asc
```

-----BEGIN PGP PUBLIC KEY BLOCK-----

```
mI0Ea09lXAEEAM4UsqtjeDzHrQKfUA+aUzgY5FmsF3YV+UpDJj30aHPYjREndM5E
+bAIR2yE2Brer3TKzqaEK0jPqVvVz+y+ixFcDj0gZ07FvX9lE4ww9f1VWTQusgJQa
UCiCiwkes5uy/RqDqgF9BH+Nd/wkeE7ZsvTkUEfUMAMwvylKioe3942219ABEBAAG0
HXN0dWRlRlbnMxdzHVkZW50UBubWpFpbC5j20+im4EEwEiADgIQTUDD4RHF+B
79ehKMN0002pwnM0vgUCa09lXAIbAwULCQgHAgYVCAKKEfGfIDAQIeAQIXgAAK
CRB0002pwnM0v1BRA/sFCIDGXzfUbQ6LHioMjd0eK5diS0NvdG5w7X2eaHuJ25Ak
Lz6KpbCiA1llh1wsA0aq2T0KgT+H7+HPxywwKeras7JX65gvc8jBaN15rwfisNy7
rKFWP7Tb7sSAYaj//2lPGjmI0xGUv66IoXmcwvHPsYMBV3ihtQJJ7xHn2WbP9Li
BgjzVzVwBbADW8BEHYeiXZYwiUxnlbQIEuCEQfOJsH7dJLPRed8MZv+lpI1tt6v
02/Io32M4gFPe+IPtnz6d+y/Im9bA02He1C+12/8B/NADQ67vx2XfziIvex/V6h
9LCySHjrtvPkB3VhQZBYNvdbDf1ls9jxdahnzIvDvRR0V3pnB27lpwARAQABiLYE
GAElACAwIQTUDD4RHF+B79ehKMN0002pwnM0vgUCa09lXAIbDAAKCRB0002pwnM0
vtUbBACwCvEW+uEVbd3170XzG6fAPtVLMm+4YvLbc30+5JnL/e1Cmne2UefVXKDh
37p09Pu6LfLwmBoqDiKwNAFzKJ5hmRbIKfHYOKsqoUQPP0nvQ8BaFxUc0RXkbVMu
qf5YyufAREE/r4MXUGtQZW58yDoDqS1RtdQcE7o2d1ymqAduYGA==
=0nW0
```

-----END PGP PUBLIC KEY BLOCK-----

```
root@kali:~#
```

```
msfadmin@metasploitable:~$ gpg --import /home/msfadmin/A_pub.asc
gpg: directory `/home/msfadmin/.gnupg' created
gpg: new configuration file `/home/msfadmin/.gnupg/gpg.conf' created
gpg: WARNING: options in `/home/msfadmin/.gnupg/gpg.conf' are not yet active during this run
gpg: keyring `/home/msfadmin/.gnupg/secring.gpg' created
gpg: keyring `/home/msfadmin/.gnupg/pubring.gpg' created
gpg: /home/msfadmin/.gnupg/trustdb.gpg: trustdb created
gpg: key C27334BE: public key "studentA <studentA@gmail.com>" imported
gpg: Total number processed: 1
gpg:      imported: 1 (RSA: 1)
msfadmin@metasploitable:~$
```

```
msfadmin@metasploitable:~$ echo "This is a secret message from Metasploitable2 to kali." >message.txt
msfadmin@metasploitable:~$ gpg --encrypt --recipient "studentA" --armor -o message_for_A.asc message.txt
gpg: FFAAEF1C: There is no assurance this key belongs to the named user

pub 1024R/FFAAEF1C 2025-10-15 studentA <studentA@gmail.com>
Primary key fingerprint: D40C 3E11 1C5F 81EF D7A1 28C3 4ED0 EDA9 C273 34BE
Subkey fingerprint: 3D0B 7B92 A3D6 7920 AB96 DB41 4A3A 5F11 FFAA EF1C

It is NOT certain that the key belongs to the person named
in the user ID. If you *really* know what you are doing,
you may answer the next question with yes.

Use this key anyway? (y/N) y
File 'message_for_A.asc' exists. Overwrite? (y/N) y
msfadmin@metasploitable:~$ ls -l message_for_A.asc
-rw-r--r-- 1 msfadmin msfadmin 453 2025-10-15 06:15 message_for_A.asc
msfadmin@metasploitable:~$
```

```
msfadmin@metasploitable:~$ scp message_for_A.asc group1@192.168.111.128:/home/group1/
group1@192.168.111.128's password:
message_for_A.asc                                100% 453      0.4KB/s   00:00
msfadmin@metasploitable:~$
```

```
root@kali:~# service ssh start
root@kali:~# gpg --decrypt /home/group1/message_for_A.asc >message_decrypted.txt
gpg: encrypted with 1024-bit RSA key, ID 4A3A5F11FFAAEF1C, created 2025-10-15
      "studentA <studentA@gmail.com>"
root@kali:~# cat message_decrypted.txt
This is a secret message from Metasploitable2 to kali.
root@kali:~#
```

3.Exercise 2

```
Nmap scan report for 192.168.111.129
Host is up (0.0036s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN,
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_ bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2             111/tcp    rpcbind
|_   100000  2             111/udp    rpcbind
|_   100003  2,3,4         2049/tcp   nfs
|_   100003  2,3,4         2049/udp   nfs
|_   100005  1,2,3         35202/udp  mountd
|_   100005  1,2,3         51528/tcp  mountd
|_   100021  1,3,4         38975/tcp  nlockmgr
|_   100021  1,3,4         40802/udp  nlockmgr
|_   100024  1             35474/tcp  status
|_   100024  1             59628/udp  status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     Java RMI Registry
1524/tcp  open  shell        Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
|_ ftp-bounce: no banner
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_   Protocol: 10
|_   Version: 5.0.51a-3ubuntu5
|_   Thread ID: 9
|_   Capabilities flags: 43564
|_   Some Capabilities: Speaks41ProtocolNew, LongColumnFlag, SupportsTransactions, SwitchToSSLAfterHandshake, ConnectWithDatabase, Support41Auth, SupportsCompression
|_   Status: Autocommit
|_   Salt: njhq*PNT--Re'/Uq-zj6
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2025-10-15T10:31:39+00:00; -3m27s from scanner time.
5900/tcp  open  vnc          VNC (protocol 3.3)
|_ vnc-info:
|_   Protocol version: 3.3
|_   Security types:
|_     VNC Authentication (2)
|_   (access denied)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/5.5
MAC Address: 00:0C:29:26:B8:9C (VMware)
Service Info: Hosts: metasploitable.localdomain, localhost, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: mean: -3m27s, deviation: 0s, median: -3m27s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)
|_   NetBIOS computer name:
|_   Workgroup: WORKGROUP\X80
|_   System time: 2025-10-15T06:30:42-04:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Port	Service
21/TCP	FTP
22/TCP	SSH
23/TCP	TALENT
25/TCP	SMTP
110/TCP	POP3

Port	Service
139/TCP	SMB
1099/TCP	JAVA RMI registry
3306/TCP	MYSQL
5900/TCP	VNC

4.Exercise 3

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# john --list=formats | grep -i sha256  
Created directory: /root/.john  
aix-ssha256, aix-ssha512, asa-md5, Bitcoin, Blackberry-ES10, WoWSRP,  
Blockchain, chap, Clipperz, cloudkeychain, cq, CRC32, shalcrypt, sha256crypt,  
HMAC-SHA1, HMAC-SHA224, HMAC-SHA256, HMAC-SHA384, HMAC-SHA512, hMailServer,  
pbkdf2-hmac-md5, PBKDF2-HMAC-SHA1, PBKDF2-HMAC-SHA256, PBKDF2-HMAC-SHA512,  
Raw-SHA256, Raw-SHA256-ng, Raw-SHA3, Raw-SHA384, Raw-SHA512-ng, Raw-SHA,  
root@kali:~# echo -n "password123" | sha256sum | awk '{print $1}' > hashes.txt  
root@kali:~# echo "created hashes.txt with:"  
created hashes.txt with:  
root@kali:~# cat hashes.txt  
ef92b778baf771e89245b89ecbc08a44a4e166c06659911881f383d4473e94f  
root@kali:~#
```

```
root@kali:~# gunzip -c /usr/share/wordlists/rockyou.txt.gz > /tmp/rockyou.txt
root@kali:~# john --format=Raw-SHA256 --wordlist=/tmp/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-SHA256 [SHA256 128/128 AVX 4x])
No password hashes left to crack (see FAQ)
root@kali:~# john --show hashes.txt
0 password hashes cracked, 1 left
root@kali:~# john --show --format=Raw-SHA256 hashes.txt
?:password123

1 password hash cracked, 0 left
root@kali:~#
```

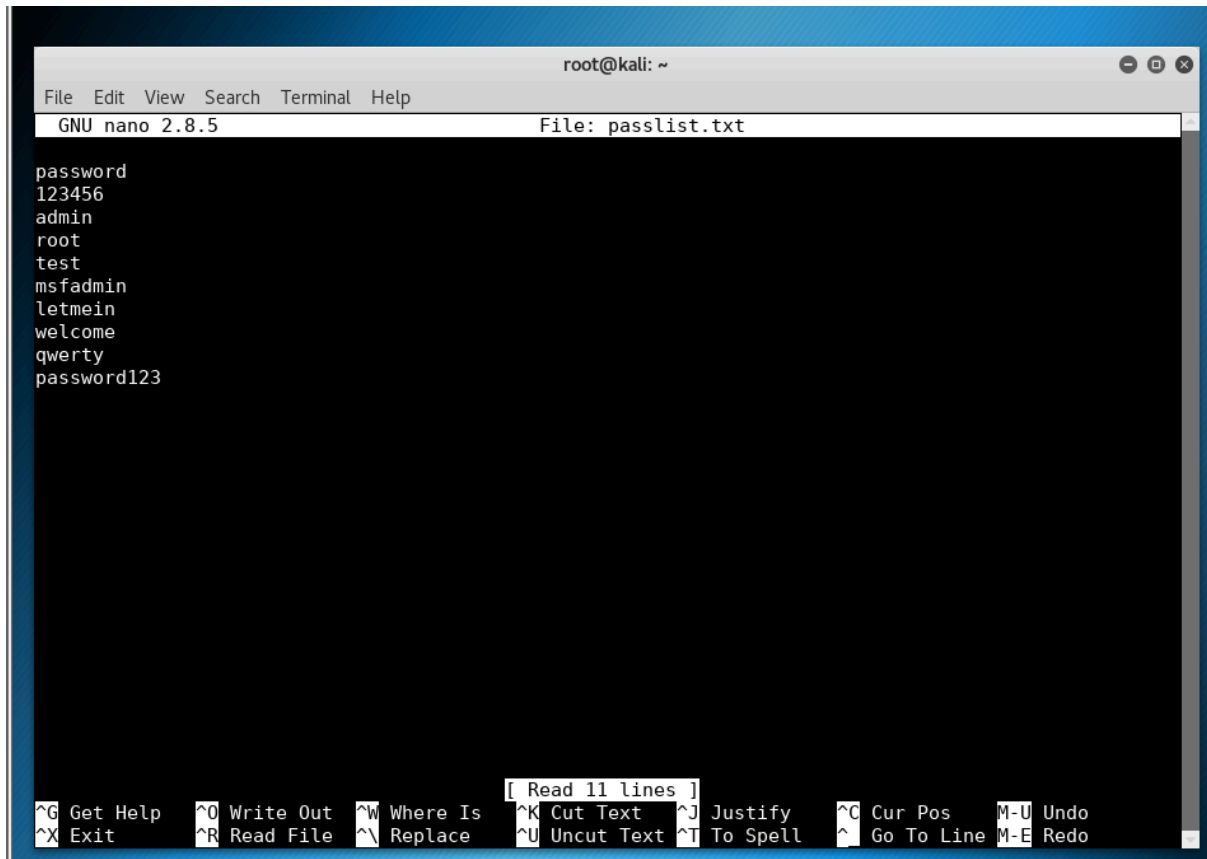
2.Solutions to Fix the SHA-256 Password Flaw

:

- Replace SHA-256 with algorithms specifically designed for password hashing (bcrypt ,scrypt, Argon2 ,PBKDF2...).
- Add a unique random salt before hashing

2.Implement

Exercise 4 — Simulated online attack & defensive iptables rule.



A screenshot of a terminal window running the nano text editor. The window title is 'root@kali: ~'. The menu bar includes 'File', 'Edit', 'View', 'Search', 'Terminal', and 'Help'. The status bar shows 'GNU nano 2.8.5' and 'File: passlist.txt'. The file content lists the following passwords: password, 123456, admin, root, test, msfadmin, letmein, welcome, qwerty, and password123. The bottom status bar displays various keyboard shortcuts for nano, including '^G Get Help', '^O Write Out', '^W Where Is', '^K Cut Text', '^J Justify', '^C Cur Pos', '^M-U Undo', '^X Exit', '^R Read File', '^_ Replace', '^U Uncut Text', '^T To Spell', '^_ Go To Line', and '^M-E Redo'. A tooltip '[Read 11 lines]' is visible over the status bar.

```
root@kali: ~
File Edit View Search Terminal Help
GNU nano 2.8.5 File: passlist.txt

password
123456
admin
root
test
msfadmin
letmein
welcome
qwerty
password123

^G Get Help  ^O Write Out  ^W Where Is  [ Read 11 lines ]  ^K Cut Text  ^J Justify  ^C Cur Pos  ^M-U Undo
^X Exit      ^R Read File  ^_ Replace   ^U Uncut Text ^T To Spell  ^_ Go To Line ^M-E Redo
```

```
root@kali:~# hydra -l msfadmin -P passlist.txt ftp://192.168.111.129 -t 4
Hydra v8.3 (c) 2016 by van Hauser/THC - Please do not use in military or secret service organization
s, or for illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2025-10-15 07:20:16
[DATA] max 4 tasks per 1 server, overall 64 tasks, 11 login tries (l:1/p:11), ~0 tries per task
[DATA] attacking service ftp on port 21
[21][ftp] host: 192.168.111.129 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2025-10-15 07:20:22
```

```
msfadmin@metasploitable:~$ sudo iptables -L -n -v
[sudo] password for msfadmin:
Sorry, try again.
[sudo] password for msfadmin:
Chain INPUT (policy ACCEPT 9777 packets, 797K bytes)
 pkts bytes target    prot opt in     out     source                   destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                   destination

Chain OUTPUT (policy ACCEPT 9701 packets, 1036K bytes)
 pkts bytes target    prot opt in     out     source                   destination

msfadmin@metasploitable:~$ sudo iptables -A INPUT -s 192.168.111.128
msfadmin@metasploitable:~$ _
```

```

The session file /hydra.restore had different type 'hydra' it is resume session.
root@kali:~# hydra -l msfadmin -P passlist.txt ftp://192.168.111.129 -t 4
Hydra v8.3 (c) 2016 by van Hauser/THC - Please do not use in military or secret service organizations, or for illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2025-10-15 07:33:58
[WARNING] Restorefile (./hydra.restore) from a previous session found, to prevent overwriting, you have 10 seconds to abort...
[DATA] max 4 tasks per 1 server, overall 64 tasks, 11 login tries (l:l/p:11), ~0 tries per task
[DATA] attacking service ftp on port 21
_
```